



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-05-27
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise - CVE / Vulnerability Threat Intelligence Report

Published: 2026-05-27 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise

1. Executive Summary

CVE-2026-48027 tracks a malicious Nx Console extension build (`18.95.0`) that was briefly published to Visual Studio Marketplace and OpenVSX, then distributed through automatic update channels to affected developer environments. CISA added the issue to the Known Exploited Vulnerabilities catalog on 2026-05-27, and NVD records critical severity with GitHub CNA CVSS v4.0 scoring of 9.3 and NVD CVSS v3.1 scoring of 9.8.

This is best understood as a software supply-chain compromise affecting developer workstations and CI/CD-adjacent systems rather than a traditional network-reachable product flaw. The strongest publicly supported risk is credential theft and downstream repository, cloud, and secret-store exposure from machines that installed the poisoned extension version during the marketplace exposure window.

2. Vulnerability Metadata

Field	Value
CVE	`CVE-2026-48027`
Product	`Nx Console` for VS Code / compatible editors
Vulnerable version	`18.95.0`
Patched / safe version	`18.100.0` or later
Weakness	`CWE-506 Embedded Malicious Code`
CVSS v4.0	`9.3 / CRITICAL` (GitHub CNA)
CVSS v3.1	`9.8 / CRITICAL` (NVD)
KEV status	added by CISA on `2026-05-27` with due date `2026-06-10`
Affected distribution channels	`Visual Studio Marketplace` and `OpenVSX`
Exposure window	approximately `18 minutes` on Visual Studio Marketplace and `36 minutes` on OpenVSX

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

3. Source Review & Confidence

Source	Contribution	Confidence
Reviewed source	CISA lists CVE-2026-48027 as `Nx Console Embedded Malicious Code Vulnerability`, states the compromised extension harvests	High-confidence official KEV source and initial intake anchor.
Reviewed source	CISA links the poisoned Nx Console extension to unauthorized access and exfiltration of GitHub-owned internal repository	High-confidence official government alert with operational response guidance.
Reviewed source	NVD records malicious version `18.95.0`,	High-confidence canonical vulnerability

	marketplace exposure windows for Visual Studio Marketplace and OpenVSX, safe ve	reference and scoring source.
Reviewed source	GitHub advisory confirms the affected and patched versions, the marketplace timeline, targeted credential classes, liste	High-confidence upstream product advisory with the richest incident-response detail.
Primary source	Vendor postmortem snippet reviewed via search results states the malicious marketplace build is no longer available and	Official vendor context, but only the surfaced search snippet was reviewed during this task because

Confidence is high because the core facts are consistent across official sources: Confidence is lower on any claim that goes beyond confirmed credential theft risk into specific follow-on intrusion outcomes for every victim. Public reporting clearly supports token and secret exposure risk, but each organization's downstream blast radius depends on what credentials were reachable from the compromised machine.

4. Vulnerability Details

The vulnerability is not a coding flaw in the normal Nx Console feature set. It is a malicious-code incident in which a poisoned extension build was published under a legitimate product identity. NVD and GitHub agree that version `18.95.0` was uploaded to the Microsoft marketplace at `12:30 UTC`, removed at `12:48 UTC`, and remained available longer on OpenVSX (`12:33 UTC` to `13:09 UTC`).

GitHub's advisory states the compromised extension fetched an obfuscated payload that harvested credentials from multiple sources on disk and in memory. Publicly named target categories include Vault tokens, npm tokens, AWS metadata- and token-derived credentials, GitHub tokens and Actions secrets, active 1Password CLI vault contents, private keys, connection strings, and other local cloud or container credentials. The same advisory notes Linux-specific persistence attempts via `sudoers` injection and lists concrete filesystem artifacts defenders can hunt for.

5. Attack Scenarios

1. A developer workstation with Nx Console installed receives the malicious `18.95.0` extension automatically from Visual Studio Marketplace or OpenVSX during the exposure window.
2. The extension downloads and runs an obfuscated second-stage payload, harvesting tokens and secrets available to the logged-in developer context.
3. Stolen GitHub, cloud, package-registry, or vault credentials are used for follow-on access to internal repositories, CI/CD systems, artifact registries, cloud workloads, or secret stores.
4. A shared engineering laptop, privileged build host, or workstation with active CLI sessions (for example Vault, GitHub, AWS, or 1Password) suffers greater downstream impact because more sensitive credentials are reachable in memory or on disk.

This risk model makes exposure severity strongly dependent on endpoint privilege, editor-extension inventory, secret hygiene, and the breadth of trust delegated to developer machines.

6. Threat Landscape & Exploitation Status

- CISA has already placed the issue in KEV, which is the clearest public signal that exploitation in the wild is established.
- CISA's 2026-05-28 alert links the poisoned Nx Console extension to unauthorized access and exfiltration of GitHub-owned internal repositories via a compromised GitHub employee device.
- The alert also emphasizes that automatic extension updates matter here: previously installed Nx Console instances may have received the malicious build without any fresh manual install.
- NVD and GitHub both classify the issue as critical.
- The reviewed vendor-blog snippet ties the compromise to a broader supply-chain chain of events and confirms that current post-`18.100.0` releases are considered safe.

This combination makes CVE-2026-48027 especially relevant to engineering-heavy organizations, managed development environments, and clients with broad CI/CD trust relationships.

7. Affected Products and Exposure

Direct exposure is limited to environments that installed the malicious Nx Console `18.95.0` build or retained its processes and persistence artifacts after installation. The most relevant exposure categories are:

- developer workstations using VS Code, Cursor, or compatible editor ecosystems with Nx Console installed
- engineering endpoints with active cloud, GitHub, package-registry, Vault, Kubernetes, Docker, or 1Password CLI sessions
- CI/CD-adjacent systems or self-hosted build hosts where editor tooling, cached secrets, or SSH keys coexist with elevated access
- organizations that allow broad automatic-extension updates without strong endpoint monitoring

Lower-risk environments include teams that did not have Nx Console installed, systems that never received `18.95.0`, and endpoints where post-exposure forensics confirm the extension, artifacts, and related processes were absent.

8. Mitigation and Workarounds

Priority actions supported by the reviewed sources:

5. Upgrade Nx Console to `18.100.0` or later everywhere it is present.
6. Kill any malicious `cat.py` processes and remove listed persistence artifacts before assuming the threat is contained.
7. Rotate all credentials reachable from potentially affected machines, including GitHub tokens, cloud credentials, SSH keys, package-registry tokens, Vault tokens, and CI/CD secrets.
8. Audit GitHub, cloud, and CI/CD logs for suspicious repository access, workflow changes, secret use, and automated-account activity after the exposure period.
9. Review extension inventories across developer fleets and tighten controls around automatic installation and update of high-trust developer tooling.
10. Conduct targeted forensic review of affected developer machines, especially systems with privileged build or release access.

9. Detection Engineering

Detection should focus on compromised developer endpoints and their downstream identities:

Signal	Telemetry Source	Analytic Goal
alert on presence of Nx Console `18.95.0` in extension inventories, package caches, or endpoint software telemetry	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
hunt for GitHub advisory indicators such as `~/local/share/kitty/cat.py`, `~/var/tmp/.gh_update_state`, `~/tmp/kitty-*`, and related Windows/macOS paths	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
investigate Python processes running `cat.py` or processes launched with `__DAEMONIZED=1`	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
review GitHub audit logs for token abuse, unexpected repository access, or suspicious automated-account commits after 2026-05-19	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

review cloud audit trails for unusual use of temporary credentials, metadata-derived tokens, Secrets Manager access, or anomalous IAM activity sourced from developer endpoints	Application logs, service metrics, EDR / crash telemetry	Spot exploitation symptoms or instability
---	--	---

9.1 Detection Query

```
// Asset and version discovery pivots for CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("dpkg -l", "rpm -qa", "apt list --installed", "pip show", "go version", "syft", "grype")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

10. Threat Hunting

Suggested hunt questions:

- Which endpoints had Nx Console installed, and did any receive version `18.95.0` during the exposure period?
- Do any Linux, macOS, or Windows developer systems contain the published GitHub-advisory filesystem artifacts?
- Were any GitHub, AWS, Vault, npm, Docker, Kubernetes, or 1Password-related credentials used abnormally after suspected exposure?
- Did any repositories, workflows, or package-publishing accounts show unusual access, automation, or secret-rotation events after 2026-05-19?
- Which engineering workstations combine editor extensions, local admin rights, and high-value secrets in ways that expand the blast radius of a similar future compromise?

10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2026-48027 Nx Console embedded malicious code supply-chain compromise
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

11. MITRE ATT&CK Mapping

The following ATT&CK mappings are supportable at a defensive-planning level:

- `T1195 Supply Chain Compromise` — the malicious code was delivered through a trusted developer extension distribution channel.

- `T1552 Credentials In Files` — GitHub's advisory explicitly states the payload harvested tokens and secrets from files such as Vault tokens, `.npmrc`, private keys, and other credential-bearing local artifacts.
- `T1528 Steal Application Access Token` — GitHub tokens, Actions secrets, and similar application tokens were explicitly targeted.

These mappings describe the observed or strongly implied tradecraft in the public advisories rather than a full intrusion chain for every victim environment.

12. Validation / Lab Testing

This intake review validated the report against official public references rather than reproducing the compromise in a lab. Analyst validation completed during this task:

- reviewed the KEV intake item and normalized intake JSON captured in the report folder
- reviewed CISA's 2026-05-28 alert covering the GitHub repository compromise and broader remediation steps
- reviewed NVD for the canonical description, CVSS data, CWE mapping, and KEV due date / required action enrichment
- reviewed GitHub advisory `GHSA-c9j4-9m59-847w` for the timeline, affected and patched versions, targeted credentials, indicators, and remediation guidance
- reviewed Nx's official postmortem snippet via search results to confirm post-incident vendor positioning that `18.100.0` and later versions are safe

No Lost Boys Cyber proof-of-concept execution was performed as part of this intake review.

13. Recommended Actions Summary

Priority	Owner	Action
High	Security / Platform Owners	Find and remediate any endpoint that installed Nx Console `18.95.0`.
Critical	Platform / Application Owners	Upgrade to `18.100.0` or later and remove malicious processes and persistence artifacts.
High	Security / Platform Owners	Rotate all credentials reachable from suspected developer endpoints; assume token exposure until disproven.
High	SOC / Detection Engineering	Investigate GitHub, cloud, CI/CD, and secret-store telemetry for suspicious follow-on activity after 2026-05-19.
High	Security / Platform Owners	Treat this as a developer-tooling supply-chain incident with potentially outsized blast radius wherever workstations hold privileged engineering secrets.

14. References

11. CISA KEV catalog entry for `CVE-2026-48027`
12. CISA alert, `Supply Chain Compromises Impact Nx Console and GitHub Repositories`
13. NVD entry for `CVE-2026-48027`
14. GitHub advisory `GHSA-c9j4-9m59-847w`, `Compromised Nx Console version 18.95.0`
15. Nx blog, `Postmortem: Nx Console v18.95.0 supply-chain compromise`